

# Business Requirements Document

## Aggregator Platform — Connecting ERP Systems & Banks

Yemen

This document sets out the business requirements for the Aggregator Platform: the authentication and user-management foundation every part of the platform is built on, followed by the platform's first delivery-scope service, Payment Points (MVP1).

|                 |                                                                                           |
|-----------------|-------------------------------------------------------------------------------------------|
| Document Status | Draft — ready for OpenAPI drafting                                                        |
| Market          | Yemen                                                                                     |
| Prepared for    | Anas                                                                                      |
| Source          | Client-provided requirements document, plus subsequent chat-based requirements gathering. |

## Introduction

### Purpose

This document defines the identity, access, and onboarding foundation that every user-facing part of the Aggregator Platform sits on top of — login, password recovery, account sign-up, and the approval controls governing who can act on the platform — and the platform's first delivery-scope service built on top of that foundation, Payment Points (MVP1). Together they are the foundation for the subsequent OpenAPI specifications.

### Scope

The platform is an aggregator connecting ERP system providers and banks/financial institutions in Yemen. This document covers: Login (email + password + OTP), Forgot Password, Merchant Sign-Up, Financial Institution Onboarding, Platform Operator provisioning, and the platform-wide maker-checker approval control (Sections 2–8); and the Payment Points service — MVP1's first delivery scope — covering payment point registration and bank approval, the two payment-confirmation methods, and notification delivery to the merchant's ERP (Sections 9–14).

### Glossary

- Admin (Platform Operator role) — can create new Platform Operator users and assign their roles; cannot act as Maker.
- Checker — a different, independent Platform Operator who reviews and gives final approval or rejection. The system must prevent the same person from being both maker and checker on one request.
- Integration User — a user representing a system-to-system connection (e.g. an ERP or core banking integration); authenticates with a username + password to obtain a bearer token, without an OTP step.
- Interactive User — a human user who logs into the platform's web interface with email + password, followed by the OTP step.
- Maker — the Platform Operator who initially creates or reviews an onboarding/approval request.
- Matching / Reconciliation — the act of linking an incoming payment notification to a specific merchant invoice.

- **Notification User** — the endpoint (URL, Port) and credentials (Username, Password) a merchant configures on the platform so payment notifications can be pushed to their ERP system. See Sections 13.3 and 14.3.
- **OTP** — a one-time password sent to the user's registered email at every login, required as a second factor before access is granted.
- **Payment Notification** — a message sent by a bank to the platform when a payment event occurs, to be routed to the correct merchant. Full schema in Section 14.2.
- **Payment Point** — a merchant-registered, bank-approved endpoint that can receive routed payment notifications. Confirmed: identified by a wallet number or a merchant point number.
- **Reader (Platform Operator role)** — read-only access to platform data; cannot create, approve, or reject anything.
- **Segregation of Duties (SoD)** — the control principle that no single individual can both create and approve the same action.
- **Sync** — the process by which an offline-captured transaction is verified against the bank once connectivity is restored.

## 2. Actors & Provisioning Overview

| Actor                                 | Description                                                   | Provisioning Model                                                                                                                                     |
|---------------------------------------|---------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------|
| Platform Operator                     | Internal platform staff.                                      | Invite-only, created by an Admin. Holds one or more roles: Maker, Checker, Reader, Admin.                                                              |
| Merchant                              | A business accepting payments through the platform.           | Self-service Sign-Up, activated only after maker-checker approval by two different Platform Operators.                                                 |
| Financial Institution (Bank / Wallet) | A bank or licensed wallet provider connected to the platform. | Never self-service. Onboarded by a Platform Operator after a contract is signed; requires maker-checker approval; credentials are emailed on approval. |

| Category              | Self-service?                 | Approval                                       | Credential delivery                                                                                                             |
|-----------------------|-------------------------------|------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------|
| Merchant              | Yes — public Sign-Up          | Maker-checker (2 different Platform Operators) | Merchant sets own password at sign-up; no credentials emailed.                                                                  |
| Financial Institution | No — contract-gated           | Maker-checker (2 different Platform Operators) | System-generated temporary password emailed on approval; forced change at first login.                                          |
| Platform Operator     | No — invite-only, by an Admin | Assigned by inviting Admin                     | Confirmed: same as Financial Institution — system-generated temporary password emailed on invite; forced change at first login. |

### 2.1 User Kinds per Actor

Confirmed: Merchant and Financial Institution accounts each have two kinds of users. Platform Operators are confirmed Interactive-only — they do not have Integration users.

| Actor             | Interactive User                       | Integration User                                                    |
|-------------------|----------------------------------------|---------------------------------------------------------------------|
| Platform Operator | Yes — required, portal login with OTP. | Confirmed: not applicable. Platform Operators are Interactive-only. |
| Merchant          | Yes — the sign-up contact; self-       | Yes — one per merchant. Confirmed symmetric with                    |

|                       |                                                                                                 |                                                                                                                                                            |
|-----------------------|-------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                       | registered, maker-checker approved.                                                             | FI: self-created by the Merchant via the portal once the Interactive account is active.                                                                    |
| Financial Institution | Yes — the onboarding contact; created by the Platform Operator (maker), maker-checker approved. | Yes — exactly one per institution. Self-created by the FI via the portal once its Interactive account is active; not provisioned by the Platform Operator. |

### 3. Process Flows

#### 3.1 Platform Operator Provisioning

1. An existing Platform Operator with the Admin role invites a new operator by email and assigns their role(s): Maker, Checker, Reader, and/or Admin.
2. The invited operator's email must match the platform's hardcoded, pre-approved domain — this restriction is set at the code/config level and cannot be changed by any Admin through the application; only a developer can change it.
3. The invitee receives a system-generated temporary password by email (same mechanism as Financial Institution onboarding) and is forced to set a new password at first login.

*Confirmed: an Admin can create new Platform Operator users and assign their roles, and may also act as Checker — but an Admin can never act as Maker. An operator may hold more than one role at once (e.g. Checker + Reader, or Admin + Checker).*

#### 3.2 Merchant Sign-Up & Approval

4. A prospective merchant completes the public Sign-Up form (Section 6.1) and sets their own password.
5. A Platform Operator, acting as Maker, reviews the submission.
6. A different Platform Operator, acting as Checker, gives final approval or rejection.
7. On approval, the account is activated; the merchant logs in (Interactive user) with the password they set, plus OTP.
8. The merchant may then self-create its Integration user via the portal, for system-to-system use (e.g. an ERP/POS connection) — see Section 3.5.

*Confirmed: the CR number alone is sufficient for the maker/checker to verify a merchant. No supporting document upload is required at this stage.*

#### 3.3 Financial Institution Onboarding

9. A contract is signed with the Financial Institution (offline, outside the platform) — a precondition.
10. A Platform Operator, acting as Maker, creates the FI record and its Interactive user: institution details, CBY license number, contract reference, and contact person.
11. A different Platform Operator, acting as Checker, reviews and approves the record.
12. On approval, the system generates a temporary password and emails Interactive-user login credentials to the FI's registered contact email.
13. The FI contact logs in (Interactive user) and is forced to set a new password on first login.
14. The FI then self-creates its own Integration user via the portal — this is not provisioned by the Platform Operator. See Section 3.5.

#### 3.4 Maker-Checker — Platform-Wide Control

Confirmed: maker-checker segregation of duties applies platform-wide to internal Platform Operator approval actions — not only Financial Institution onboarding, but Merchant approval and any future internal approval workflow.

*Confirmed: this does NOT extend to a Bank's own approval of a merchant's payment point (US-PP-03 / BR-PP-07). That remains a single-approver action by the Financial Institution — no maker-checker required on the bank's side. Maker-checker is specifically an internal Platform Operator control.*

### 3.5 Interactive vs. Integration Users

Confirmed: both Merchants and Financial Institutions have two distinct kinds of users (see Section 2.1):

- Interactive user — authenticates with email + password + OTP, for humans using the platform's web interface.
- Integration user — authenticates with username + password to obtain a bearer token, with no OTP step, for system-to-system calls (e.g. an ERP submitting payments, or a bank sending payment notifications).

Confirmed: the Bank/Wallet Login API documented in Section 14.1 is the Integration user's authentication endpoint for both Financial Institutions and Merchants — request/response shape as originally specified (UserName + Password in; IsSuccess/Code/Data.Token/Message out; 401 on invalid credentials). This is why it has no OTP step.

*Confirmed: the Integration user is self-created by the Merchant or Financial Institution via the portal, once its Interactive user is active — it is not provisioned by a Platform Operator maker/checker. Exactly one Integration user per Merchant and per Financial Institution. Creation shows the user its Username, Password, URL, and Port; credentials are a username + password pair, not an API key/secret pair.*

Maintenance after creation (confirmed):

- Changing an existing Integration user's details requires full maker-checker approval (two different Platform Operators) — for both Merchant and Financial Institution.
- Credential rotation is an exception for Financial Institutions: the FI may rotate its own Integration credential itself, at any time, with no approval needed.
- For Merchants, credential rotation is not exempted — it follows the same maker-checker approval as any other detail change.
- Integration bearer token expiry/refresh terms are mutually agreed per Merchant/Financial Institution, rather than a single fixed platform-wide value. Interactive session/token lifetime, by contrast, is fixed: 30 minutes for Platform Operators, 5 minutes for Merchant and Financial Institution users.

## 4. Business Rules

- BR-AUTH-1 Every user (Platform Operator, Merchant, Financial Institution) authenticates using an email or username and password.
- BR-AUTH-2 For Interactive users, on every successful password check the system sends a one-time password (OTP) to the user's registered email; login completes only after the correct OTP is entered.
- BR-AUTH-3 Integration users authenticate with a username and password to obtain a bearer token; the OTP step does not apply to Integration users.
- BR-AUTH-4 Each Merchant and each Financial Institution may have exactly one Integration user, self-created via the portal once the account's Interactive user is active. Integration user creation does not require Platform Operator maker-checker approval.
- BR-AUTH-5 Users can reset a forgotten password via an email-based reset flow.
- BR-AUTH-6 Only Merchants may self-register through the public Sign-Up screen.
- BR-AUTH-7 Financial Institution accounts are created exclusively by Platform Operators, only after a contract has been signed.
- BR-AUTH-8 Platform Operator accounts are created exclusively by an existing Platform Operator (invite-only); there is no public sign-up for this category.
- BR-AUTH-9 Every Merchant sign-up and every Financial Institution onboarding must pass through maker-checker approval: one Platform Operator creates/reviews (maker), a different Platform Operator gives final approval (checker).

- BR-AUTH-10 The system must prevent the same Platform Operator from acting as both maker and checker on the same request.
- BR-AUTH-11 On Financial Institution approval, the system auto-generates a temporary password for the Interactive user and emails it to the institution's registered contact email; the contact must set a new password at first login.
- BR-AUTH-12 A Merchant or Financial Institution account cannot log in until it has passed checker approval.
- BR-AUTH-13 An OTP is valid for 5 minutes from generation. After 10 consecutive incorrect OTP attempts, the account is locked for 3 hours.
- BR-AUTH-14 Merchant approval by the maker/checker relies on the Commercial Registration (CR) number alone; no supporting document upload is required.
- BR-AUTH-15 Completing a password reset invalidates all other active sessions/tokens for that user.
- BR-AUTH-16 The Platform Operator role set is Maker, Checker, Reader, and Admin. An Admin can create new Platform Operator users and assign their roles, but cannot act as Maker.
- BR-AUTH-17 Platform Operator accounts must use a pre-approved, hardcoded email domain; this restriction is enforced at the code/config level and can only be changed by a developer — no Admin can create an operator on another domain through the application.
- BR-AUTH-18 The password policy requires a minimum of 8 characters, including a mix of letters and numbers.
- BR-AUTH-19 On rejection of a Merchant or Financial Institution application, the applicant may resubmit, and a reason code is communicated to them.
- BR-AUTH-20 Interactive-user session/token lifetime is 30 minutes for Platform Operators and 5 minutes for Merchant and Financial Institution users.
- BR-AUTH-21 Integration-user bearer token expiry and refresh terms are mutually agreed per Merchant/Financial Institution, rather than a fixed platform-wide value.
- BR-AUTH-22 A Financial Institution's Institution Type is limited to exactly two values: Bank or Wallet.
- BR-AUTH-23 A Financial Institution's contract record captures: contract number, signed date, expiry date, agreed fee per request, an auto-renewal indicator, and a termination-requested indicator. If termination-requested is checked, a termination notice date is required.
- BR-AUTH-24 The Merchant Sign-Up form includes an ERP System field, selected from a dropdown list.
- BR-AUTH-25 Integration user creation is fully self-service for both Merchant and Financial Institution accounts and does not require Platform Operator maker-checker approval.
- BR-AUTH-26 Changing the details of an existing Integration user requires full maker-checker approval, for both Merchant and Financial Institution accounts — except that a Financial Institution may rotate its own Integration credential itself at any time, without approval. A Merchant's credential rotation is not exempted and follows the same maker-checker approval.
- BR-AUTH-27 Platform Operators do not have Integration users; the Interactive/Integration split applies only to Merchant and Financial Institution accounts.
- BR-AUTH-28 An Admin may also act as Checker, but never as Maker. A Platform Operator may hold more than one role at once (e.g. Checker + Reader, or Admin + Checker).
- BR-AUTH-29 A Financial Institution's Integration password is masked by default in the portal; unmasking (viewing) it or regenerating it both require the Financial Institution to complete an OTP step first.
- BR-AUTH-30 Platform Operators maintain an ERP System List (name of system, company name, contact person, email address, contract date, expiry) via a dedicated screen; the Merchant Sign-Up ERP System dropdown is populated from this list.
- BR-AUTH-31 An ERP System List entry requires the same maker-checker approval as Merchant and Financial Institution onboarding; only an Approved entry appears in the Merchant Sign-Up dropdown.
- BR-AUTH-32 A Merchant may be onboarded either via public self-service Sign-Up, or via a Platform Operator creating the record on the merchant's behalf; both paths require full maker-checker approval before the account can log in.
- BR-AUTH-33 Platform Operator access to individual menu screens is granted per operator, managed by an Admin, in addition to whatever access the operator's Role(s) provide.

**BR-AUTH-34** A Merchant may self-edit their own business profile and contact-person details directly, without maker-checker approval. The same applies to a Financial Institution's contact-person details; the Financial Institution's contract/license details remain read-only to the institution.

## 5. Data Entities (Proposed)

*Proposed based on the flows above; to be validated before carrying into the API design.*

| Entity             | Proposed Key Attributes                                                                                                                                                                                                                           | Notes                                                                                                                                                                                                                                                                                                                                                                       |
|--------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| User               | Id, Email/Username, PasswordHash, UserType (PlatformOperator / Merchant / FinancialInstitution), UserKind (Interactive / Integration), OwnerAccountId, Status (Pending / Approved / Rejected / Active / Suspended), MustChangePassword, CreatedAt | Single user table across all categories, differentiated by UserType and UserKind. OwnerAccountId links an Integration user back to its parent Merchant/FI account.                                                                                                                                                                                                          |
| Role               | Id, Name (Maker / Checker / Reader / Admin)                                                                                                                                                                                                       | Confirmed set of Platform Operator roles. Admin creates Platform Operator users and assigns roles, and may also act as Checker — but never as Maker.                                                                                                                                                                                                                        |
| UserRole           | UserId, RoleId                                                                                                                                                                                                                                    | Many-to-many — confirmed: an operator may hold more than one role at once (e.g. Checker + Reader, or Admin + Checker).                                                                                                                                                                                                                                                      |
| ApprovalRequest    | Id, EntityType (Merchant / FinancialInstitution / IntegrationUserChange / ERPSystem), EntityId, MakerUserId, MakerActionAt, CheckerUserId, CheckerActionAt, Status (PendingChecker / Approved / Rejected), RejectionReason                        | Generic internal maker-checker record, covering Merchant and Financial Institution onboarding, Integration user detail-change/rotation requests (see Section 3.5), and ERP System List entries (see Section 6.5). Confirmed not to extend to a Bank's own approval of a merchant payment point (see Section 3.4) — that stays a single-approver action outside this entity. |
| OTP                | Id, UserId, Code, GeneratedAt, ExpiresAt, ConsumedAt                                                                                                                                                                                              | Generated at every Interactive-user login attempt after password verification. Not used for Integration users.                                                                                                                                                                                                                                                              |
| PasswordResetToken | Id, UserId, Token, ExpiresAt, ConsumedAt                                                                                                                                                                                                          | Supports Forgot Password.                                                                                                                                                                                                                                                                                                                                                   |
| Contract Reference | ContractNumber, SignedDate, ExpiryDate, AgreedFeePerRequest, AutoRenewal (bool), TerminationRequested (bool), TerminationNoticeDate (required if TerminationRequested)                                                                            | Confirmed field set for the FI onboarding precondition.                                                                                                                                                                                                                                                                                                                     |
| ERPSystem          | Id, SystemName, CompanyName, ContactPersonName, ContactEmail, ContractDate, ExpiryDate, Status (Pending / Approved / Rejected), CreatedByOperatorId, CreatedAt                                                                                    | Reference list maintained by Platform Operators via a dedicated "ERP System List" screen; populates the Merchant Sign-Up ERP System dropdown (Section 6.1). Confirmed: goes through the same maker-checker approval as FI onboarding.                                                                                                                                       |
| ScreenPermission   | Id, OperatorUserId, ScreenKey, GrantedByOperatorId, GrantedAt                                                                                                                                                                                     | Confirmed: menu/screen access for Platform Operators is granted per individual operator, not only inherited from their Role(s). Managed by an Admin (Section 8.1). An operator sees only the screens they've been granted, in addition to whatever their Role(s) permit.                                                                                                    |

## 6. Sign-Up / Onboarding Field Definitions

## 6.1 Merchant Sign-Up Form

| Field                               | Notes                                                                                                                                                           |
|-------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Business legal name                 |                                                                                                                                                                 |
| Commercial Registration (CR) number | Yemen entities — assumed mandatory                                                                                                                              |
| Business type / industry            | e.g. Retail, F&B, Services                                                                                                                                      |
| City / address                      |                                                                                                                                                                 |
| Contact person full name            |                                                                                                                                                                 |
| Contact person email                | Used as login username                                                                                                                                          |
| Contact person phone number         | Candidate for SMS fallback — not yet decided                                                                                                                    |
| ERP system                          | Dropdown/select list — merchant selects the ERP system they use. Confirmed: populated from the ERP System List, maintained by Platform Operators (Section 6.5). |
| Password                            | Set by the merchant at sign-up; + confirm password                                                                                                              |

## 6.2 Financial Institution Record

| Field                                      | Entered by       | Notes                                                                                             |
|--------------------------------------------|------------------|---------------------------------------------------------------------------------------------------|
| Institution legal name                     | Maker            |                                                                                                   |
| Institution type                           | Maker            | Confirmed: exactly two options — Bank or Wallet                                                   |
| Central Bank of Yemen (CBY) license number | Maker            |                                                                                                   |
| Contract number                            | Maker            | Captures the onboarding precondition                                                              |
| Contract signed date                       | Maker            |                                                                                                   |
| Contract expiry date                       | Maker            |                                                                                                   |
| Agreed fee per request                     | Maker            | Pricing term from the contract                                                                    |
| Auto-renewal (checkbox)                    | Maker            | Checked if the contract renews automatically                                                      |
| Termination requested (checkbox)           | Maker            | Checked if the FI has requested termination                                                       |
| Termination notice date                    | Maker            | Required only if "Termination requested" is checked                                               |
| Integration token expiry & refresh policy  | Maker            | Mutually agreed per institution — not a fixed platform-wide value; captured as part of onboarding |
| Contact person name, email, phone          | Maker            | Credentials are emailed to this address on checker approval                                       |
| Approval decision                          | Checker          | Approve or reject; must be a different user than the maker                                        |
| Password                                   | System-generated | Temporary password, forced change at first login                                                  |

## 6.3 Platform Operator Invite

| Field                      | Notes                                                                                                                                                                              |
|----------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Full name                  |                                                                                                                                                                                    |
| Work email                 | Login username                                                                                                                                                                     |
| Role / permission level(s) | Confirmed set: Maker, Checker, Reader, Admin. Assigned by the inviting Admin. An operator may hold more than one role at once; Admin may also act as Checker, but never as Maker.  |
| Email domain               | Must match the platform's hardcoded approved domain — enforced at the code/config level; no Admin can change this or invite an operator on another domain through the application. |
| Password                   | Confirmed: same delivery mechanism as Financial Institution — system-generated temporary password, forced change at first login.                                                   |

## 6.4 Integration User Creation (Merchant & Financial Institution)

Self-service, triggered by the account's Interactive user once Active. Confirmed: credential is a username + password pair (not an API key/secret pair). On creation, the screen displays: Username, Password, URL, Port. The password is stored masked by default; the Financial Institution may unmask (view) or regenerate it later, but both of those actions require completing an OTP step first.

Maintenance: changing details requires maker-checker approval for both Merchant and Financial Institution. Credential rotation is the one exception — self-service for Financial Institutions, but still maker-checker for Merchants. See Section 3.5.

## 6.5 ERP System List (Platform Operator screen)

Confirmed: a dedicated "ERP System List" screen in the Platform Operator menu, where operators define the ERP systems merchants can select from during Sign-Up (Section 6.1). Confirmed: entries require the same maker-checker approval as Merchant and Financial Institution onboarding — a Maker adds the entry, a different Checker approves it, and only Approved entries appear in the dropdown.

| Field             | Entered by | Notes                                                                                                                      |
|-------------------|------------|----------------------------------------------------------------------------------------------------------------------------|
| Name of system    | Maker      |                                                                                                                            |
| Company name      | Maker      | The ERP provider's company                                                                                                 |
| Contact person    | Maker      |                                                                                                                            |
| Email address     | Maker      |                                                                                                                            |
| Contract date     | Maker      |                                                                                                                            |
| Expiry            | Maker      |                                                                                                                            |
| Approval decision | Checker    | Approve or reject; must be a different user than the maker. Only Approved entries appear in the Merchant Sign-Up dropdown. |

# 7. User Stories & Acceptance Criteria

## 7.1 Login

### US-AUTH-01 — Interactive login with OTP

As an Interactive user (Platform Operator, Merchant, or Financial Institution contact), I want to log in with my email and password and then confirm a one-time code sent to my email, so that my account is protected by two-factor authentication.

- Given correct email/password, when submitted, then an OTP is generated and emailed to the user.
- The user must enter the correct OTP within its validity window to complete login.
- An incorrect password or OTP is rejected without revealing which of the two was wrong (avoids account enumeration).
- The OTP is valid for 5 minutes from generation.
- After 10 incorrect OTP attempts, the account is locked for 3 hours before another login attempt is allowed.

## US-AUTH-02 — Integration user login (no OTP)

As an Integration user representing a Merchant's or Financial Institution's system, I want to authenticate with a username and password to receive a bearer token, without an OTP step, so that automated system-to-system calls aren't blocked waiting on a human to enter a code.

- Given correct username/password for an Integration user, when submitted, then a bearer token is issued directly — no OTP is generated or required.
- This corresponds to the Bank/Wallet Login API documented in Section 14.1 — confirmed to apply to both Financial Institution and Merchant Integration users. See Section 3.5.
- Token expiry/refresh terms for this Integration session are mutually agreed per Merchant/Financial Institution, not a fixed platform-wide value.

## 7.2 Forgot Password

### US-AUTH-03 — Reset a forgotten password

As any registered Interactive user, I want to reset my password if I forget it, so that I can regain access to my account.

- User requests a reset by submitting their email.
- System sends a reset link/OTP to that email, expiring after a set window.
- User sets a new password to regain access.
- Completing a password reset invalidates all other active sessions/tokens for that user, requiring re-authentication everywhere else.

## 7.3 Merchant Sign-Up & Onboarding

### US-AUTH-04 — Merchant registers

As a prospective Merchant, I want to register on the platform using the Sign-Up form, so that I can begin onboarding.

- Account is created in a Pending status; the merchant cannot log in until approved.
- Merchant receives confirmation that their application was submitted.

### US-AUTH-05 — Maker reviews a merchant application

As a Platform Operator, I want to review a merchant's sign-up as the maker, so the request can move to a second operator for final approval.

### US-AUTH-06 — Checker approves or rejects a merchant application

As a different Platform Operator, I want to approve or reject a merchant's sign-up as the checker, so that only vetted merchants become active.

- The system blocks the checker step if the checker is the same user as the maker.

- On approval, the merchant account is activated and notified.
- On rejection, the merchant is notified with a reason code and may resubmit their application.

### US-AUTH-07 — Merchant creates its Integration user

As a Merchant (Interactive user), I want to create my own Integration user via the portal once my account is active, so that my ERP/POS system can connect to the platform directly.

- Available only once the Merchant's Interactive account is Active.
- A Merchant may have at most one Integration user.
- Confirmed: creation itself is self-service, symmetric with the Financial Institution flow. However, unlike the FI, a Merchant's Integration credential rotation is NOT self-service — see US-AUTH-13.

### US-AUTH-19 — Platform Operator onboards a Merchant on their behalf

As a Platform Operator acting as Maker, I want to create a Merchant account directly on behalf of a business, so that merchants who aren't onboarding themselves can still be brought onto the platform.

- Confirmed: both channels exist — public self-service Sign-Up (US-AUTH-04) and Platform-Operator-assisted onboarding — for creating a Merchant account.
- An operator-created Merchant record follows the same maker-checker approval as a self-service Sign-Up (US-AUTH-05/06); the system blocks the checker step if the checker is the same user as the maker.
- On approval, the merchant is notified and can log in the same way as a self-registered merchant.

## 7.4 Financial Institution Onboarding

### US-AUTH-08 — Maker creates a Financial Institution record

As a Platform Operator acting as Maker, I want to create a Financial Institution record and its Interactive user, referencing the signed contract, so the institution can be onboarded.

### US-AUTH-09 — Checker approves a Financial Institution record

As a different Platform Operator acting as Checker, I want to approve the Financial Institution record, so that credentials are issued only to a verified institution.

- The system blocks the checker step if the checker is the same user as the maker.

### US-AUTH-10 — Financial Institution receives Interactive credentials

As a Financial Institution contact, I want to receive my Interactive-user login credentials by email once my institution is approved, and be forced to set a new password on first login, so my account is secure from the start.

### US-AUTH-11 — Financial Institution creates its Integration user

As a Financial Institution contact (Interactive user), I want to create my institution's Integration user via the portal once my account is active, so that our core banking/notification system can connect to the platform directly, without going through a Platform Operator.

- Available only once the Financial Institution's Interactive account is Active.
- A Financial Institution may have at most one Integration user.
- This is not subject to maker-checker approval — it is self-service.

## 7.5 Platform Operator Provisioning

### US-AUTH-12 — Invite a new Platform Operator

As a Platform Operator with the Admin role, I want to invite a new operator and assign their role(s), so that the internal team can grow with appropriate access control.

- Only an Admin can invite new operators; the invited email must match the platform's hardcoded domain.

- The Admin performing this action can never also act as Maker — that combination is not permitted for the same person, though an operator may otherwise hold multiple roles (e.g. Admin + Checker).

## 7.6 Integration User Maintenance

### US-AUTH-13 — Merchant requests an Integration user change (maker-checker)

As a Merchant, I want to request a change to my Integration user's details or credential, so that I can update how my ERP/POS system connects — subject to Platform Operator review, since this isn't a self-service action for Merchants.

- Any change, including credential rotation, requires maker-checker approval (two different Platform Operators).

### US-AUTH-15 — Financial Institution rotates its own Integration credential (self-service)

As a Financial Institution contact, I want to rotate my institution's Integration credential myself, at any time, without waiting for approval, so that I can respond quickly to a security concern or routine rotation policy.

- No maker-checker approval is required for this specific action.
- Regenerating the credential requires completing an OTP step first.
- The previous credential should stop working once the new one is issued (exact invalidation timing not yet specified).

### US-AUTH-16 — Financial Institution views its masked Integration password

As a Financial Institution contact, I want to unmask and view my institution's Integration password from the portal, so that I can retrieve it again without needing to rotate it.

- The password is masked by default in the portal.
- Unmasking it requires completing an OTP step first, the same as regenerating it.

## 7.7 ERP System List Management

### US-AUTH-17 — Maker adds an ERP System List entry

As a Platform Operator acting as Maker, I want to define a new ERP system (name of system, company name, contact person, email address, contract date, expiry), so it can be reviewed before appearing in the Merchant Sign-Up dropdown.

- The entry is Pending until a different Platform Operator, acting as Checker, approves it.

### US-AUTH-18 — Checker approves an ERP System List entry

As a different Platform Operator acting as Checker, I want to review and approve or reject a new ERP system entry, so that only verified ERP providers appear in the Merchant Sign-Up dropdown.

- The system blocks the checker step if the checker is the same user as the maker.
- Only an Approved entry appears in the Merchant Sign-Up ERP System dropdown (Section 6.1).

## 7.8 Platform Operator Screen Permissions

### US-AUTH-20 — Admin grants/revokes screen permissions for an individual operator

As a Platform Operator with the Admin role, I want to grant or revoke access to individual menu screens for a specific operator, so that access can be tailored beyond what their Role(s) alone would provide.

- Confirmed: screen permission is granted per individual operator (not only per Role).
- An operator sees only the screens covered by their Role(s) plus any screens individually granted to them by an Admin.

- Only an Admin can manage screen permissions; this is configured from the Platform Operators menu (Section 8.1).

## 7.9 Profile Self-Service

### US-AUTH-21 — Merchant or Financial Institution edits own profile details

As a Merchant or Financial Institution contact, I want to update my own business profile and contact-person details directly, so that routine information stays current without waiting on Platform Operator approval.

- Confirmed: a Merchant may self-edit their business profile and contact-person details — no maker-checker approval required.
- Confirmed: a Financial Institution may self-edit their contact-person details the same way; the institution's contract/license details remain read-only (owned by the Platform Operator maker/checker record).

## 8. Menu & Screen Structure per User Category

*Proposed navigation for each of the three user categories, based on the flows and rules already confirmed above. Structure and grouping are proposed; items marked "confirmed" reflect an explicit decision already made elsewhere in this document.*

### 8.1 Platform Operator Menu

- Dashboard — pending-request counts overall, per Financial Institution, and per ERP System; active-merchant count; payment point approval SLA tracking (1 working day — see BR-PP-18); time filters for hour / 24 hours / today / week / month.
- Merchant Management — Onboard New Merchant (Maker, US-AUTH-19); Pending Approvals (Maker/Checker queue); All Merchants (list/search/view).
- Financial Institution Management — Onboard New FI (Maker); Pending Approvals (Checker); All Financial Institutions (list/search/view).
- ERP System List — Add ERP System (Maker); Pending Approvals (Checker); All ERP Systems (list/search/view).
- Integration User Requests — pending change/rotation requests from Merchants and Financial Institutions (Checker queue).
- Platform Operators (Admin-only) — Invite New Operator; Manage Operators & Roles; Screen Permissions (per-individual-operator, US-AUTH-20).
- Reports / Audit Log — scope not yet defined; see Section 15.
- Account Settings — profile, change password.

*Confirmed: each Platform Operator only sees the menu screens they've been granted access to — via their Role(s), plus any screens individually granted by an Admin (Section 7.8).*

### 8.2 Merchant Menu

- Dashboard (proposed).
- Payment Points — My Payment Points (status: Pending / Approved / Rejected); Add Payment Point (bank-selection list only includes already-onboarded, Approved Financial Institutions — see BR-PP-10).
- Integration — My Integration User (view masked credential; request a change via maker-checker — not self-service for a Merchant, see US-AUTH-13).
- Notification Delivery — Notification User: submit the ERP system's endpoint (URL, Port) and credentials (Username, Password) so the platform can push payment notifications to it; requires Platform Operator maker-checker approval before it becomes Approved (see Section 13.3 / BR-PP-17).
- Account Settings — business profile and contact-person details (self-editable, no approval required — US-AUTH-21); change password.

*Confirmed: My Integration User and Notification User are separate credentials for opposite directions. Integration User is how the merchant's ERP authenticates into the platform (Section 6.4). Notification User is the endpoint the platform pushes payment notifications to (Sections 10.3, 13.3, 14.3).*

### 8.3 Financial Institution Menu

- Dashboard (proposed).
- Payment Point Approvals — Pending Approvals (from merchants); All Payment Points (history).
- Notifications — a log/history view of payment notifications sent via the Integration API (the sending itself happens machine-to-machine).
- Integration User — View / Unmask Credential (OTP-gated); Regenerate Credential (self-service, OTP-gated, US-AUTH-15); Request Detail Change (maker-checker — see BR-AUTH-26).
- Institution Profile — contract/license details (read-only); contact-person details (self-editable, no approval required — US-AUTH-21).
- Account Settings — change password.

*Having established the platform's authentication and user-management foundation above, the remainder of this document covers the platform's first delivery-scope service, built on top of it: Payment Points (MVP1).*

## 9. Actors & Stakeholders

| Actor                        | Description                                                          | Role in Payment Points                                                                                                                                                                                                                                                                                                                                                                |
|------------------------------|----------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Financial Institution (Bank) | A bank or licensed wallet provider connected to the platform.        | Sends payment notifications; approves merchant payment points linked to it.                                                                                                                                                                                                                                                                                                           |
| Merchant                     | A business accepting payments through the platform.                  | Registers payment points; links banks; matches incoming notifications to invoices.                                                                                                                                                                                                                                                                                                    |
| Customer / Payer             | The end customer paying the merchant.                                | Initiates the payment at the bank/wallet; the resulting transaction is matched to an invoice either by the merchant scanning a QR code shown on the customer's phone or manually entering the transaction code/reference the customer provides (Method A), or by the merchant tapping the incoming payment notification on their cashier system to link it to the invoice (Method B). |
| Platform (Aggregator)        | The platform itself — the system connecting ERP providers and banks. | Owns user provisioning, routing of notifications, and approval workflow state.                                                                                                                                                                                                                                                                                                        |

## 10. High-Level Process Overview

### 10.1 Onboarding & Linking

- A bank is provisioned with a platform user, enabling it to send payment notifications to subscribed merchants.
- A merchant is provisioned with a platform user and links one or more banks and payment points to their account.
- Each payment point a merchant adds must be approved by the relevant bank before it can route live notifications.

- The merchant also configures a Notification User — their ERP system's endpoint (URL, Port) and credentials (Username, Password) — so the platform can push payment notifications directly to it; this also requires Platform Operator approval before it's used (see Section 10.3).

## 10.2 Payment Confirmation

- Method A — Code entry: customer pays via their bank/wallet app, then the merchant links the payment to an invoice either by scanning a QR code shown on the customer's phone, or by manually entering the transaction code/reference provided by the customer. Works without a constant internet connection; the match is verified once the device syncs.
- Method B — Notification tap: customer pays, and the incoming payment notification appears on the merchant's cashier system; the merchant taps the notification there to link it to the invoice. Requires an active connection.

## 10.3 Notification Delivery

- Confirmed: notification delivery is a push from the platform to the merchant's ERP system, not the merchant app polling the platform.
- The merchant submits a Notification User — endpoint URL, Port, Username, and Password for their ERP — via the Merchant menu.
- A Platform Operator (Checker) must approve the Notification User (maker-checker) before it becomes Approved.
- Once Approved, the platform pushes every Payment Notification it receives from a bank to that endpoint.

# 11. Business Rules — Payment Points

BR-PP-1 Each Financial Institution (bank) participating in the platform must have a dedicated platform user account.

BR-PP-2 A bank's platform user is authorized to send payment notifications to merchants subscribed on the platform.

BR-PP-3 Each merchant participating in the platform must have a dedicated platform user account.

BR-PP-4 A merchant account can be linked to one or more banks and one or more payment points.

BR-PP-5 Incoming payment notifications must be routed to the correct merchant based on the payment point that received them.

BR-PP-6 A newly added payment point remains in a Pending Approval state until the linked bank approves it.

BR-PP-7 The bank must verify that a submitted payment point genuinely belongs to the correct merchant and to that bank before approving it.

BR-PP-8 A payment point cannot receive or route live payment notifications until it has been approved by the bank.

BR-PP-9 The platform must support two payment-confirmation methods, each with different connectivity requirements (see Section 10.2).

BR-PP-10 When a merchant adds a payment point, the bank-selection list must only include Financial Institutions that are already onboarded and in Approved status; a bank that has not completed onboarding must not appear as a selectable option.

BR-PP-11 A Payment Point identifies either a wallet number or a merchant point number.

BR-PP-12 On approval or rejection of a payment point request, the merchant is notified of the bank's decision; a rejection notification includes a reason.

BR-PP-13 For Method A, the platform's responsibility is limited to confirming that the transaction code/reference entered or scanned by the merchant matches the value already relayed from the bank via the Payment Notification API; the platform is not responsible for independently validating it against the bank.

BR-PP-14 Duplicate or retried Payment Notifications from a bank are de-duplicated using TransactionId, which is unique per transaction per bank.

BR-PP-15 The platform supports multiple currencies for payment notifications and payment points: USD, SAR, and YER.

BR-PP-16 When a payment notification cannot be automatically matched to an invoice — a Method A conflict, a mismatch, or no matching notification received — reconciliation is manual and happens directly between the merchant and the bank; the platform does not provide an automated refund or escalation path.

BR-PP-17 Payment notifications are delivered by the platform pushing them to a Notification User endpoint (URL, Port, Username, Password) that the merchant configures; this configuration requires Platform Operator maker-checker approval before it becomes active, and only an Approved Notification User is used for delivery.

BR-PP-18 The approval SLA for a payment point request is 1 working day, tracked on the Platform Operator dashboard. On rejection, the bank enters a free-text reason via a text field on the approval screen — there is no fixed reason-code taxonomy.

## 12. Data Entities (Proposed) — Payment Points

*The source requirements describe behavior but not a data model. The entities below are proposed based on that behavior and should be validated with you before being carried into the API design.*

| Entity               | Proposed Key Attributes                                                                                                                                                                                                                                                                                                                                                                        | Notes                                                                                                                                                                                                                                 |
|----------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bank                 | Id, Name, Status                                                                                                                                                                                                                                                                                                                                                                               | Onboarded by the platform; owns one or more Bank Users.                                                                                                                                                                               |
| Bank User            | Id, BankId, Username, Role                                                                                                                                                                                                                                                                                                                                                                     | Authenticates via the Login API; sends notifications; approves payment points.                                                                                                                                                        |
| Merchant             | Id, Name, Status                                                                                                                                                                                                                                                                                                                                                                               | Owns one or more Merchant Users, banks, and payment points.                                                                                                                                                                           |
| Merchant User        | Id, MerchantId, Username, Role                                                                                                                                                                                                                                                                                                                                                                 | Authenticates via the Login API; manages payment points and invoices.                                                                                                                                                                 |
| Payment Point        | Id, MerchantId, BankId, PointCode (wallet number or merchant point number), Status (Pending / Approved / Rejected), CreatedAt, ApprovedAt                                                                                                                                                                                                                                                      | Confirmed: PointCode identifies a wallet number or a merchant point number. Status model is proposed — not explicit in the source. Only "approved" points may route live notifications.                                               |
| Payment Notification | Id (platform), BankId, TransactionId (bank's unique payment ID), TransactionStatus (Paid = "00002" / Refunded = "00007"), TransactionDate, Amount, Currency (USD / SAR / YER), PointNumber, CashierId, CashierName, CustomerName (masked), CashierActivityName (branch), Notes, Name (mandatory response label), Reference (platform-generated, returned to the bank), ReceivedAt, MatchStatus | Confirmed field set for the Bank → Platform Payment Notification API; TransactionId is the de-duplication/idempotency key. Full request/response schema and sample payloads in Section 14.2.                                          |
| Notification User    | Id, MerchantId, Username, Password, URL, Port, Status (Pending / Approved / Rejected), CreatedAt                                                                                                                                                                                                                                                                                               | Confirmed: the merchant submits these to configure their ERP's push endpoint; requires Platform Operator maker-checker approval before use (Section 13.3). Once Approved, the platform pushes Payment Notifications to this endpoint. |
| Invoice              | Id, MerchantId, InvoiceNumber, Amount, Status                                                                                                                                                                                                                                                                                                                                                  | Merchant-side reference the payment must be matched against.                                                                                                                                                                          |
| Payment Match        | Id, PaymentNotificationId, InvoiceId, Method (CodeEntry / NotificationTap), MatchedAt, SyncStatus                                                                                                                                                                                                                                                                                              | SyncStatus needed to support the offline code-entry method.                                                                                                                                                                           |

## 13. User Stories & Acceptance Criteria — Payment Points

## 13.1 Onboarding & Linking

### US-PP-01 — Bank provisioning

As a Financial Institution, I want a platform user account, so that I can send payment notifications to merchants subscribed on the platform.

- Given the bank has been onboarded, when its account is created, then it receives credentials to authenticate (see Section 14.1, Login API).
- The bank must authenticate before sending any notification.

*Confirmed: Financial Institution accounts are created exclusively by a Platform Operator (Maker) after a contract is signed, with Checker approval — never bank self-registration (Section 3.3).*

### US-PP-02 — Merchant registration & linking

As a Merchant, I want to register on the platform and link my banks and payment points, so that incoming payment notifications route correctly to me.

- Merchant can create an account and authenticate — either via public Sign-Up, or via a Platform Operator onboarding them directly; both paths require maker-checker approval (see Section 4, Business Rules).
- Merchant can add one or more banks and one or more payment points under their account.
- When adding a payment point, the bank-selection list only includes Financial Institutions that are already onboarded (Approved status) on the platform — a bank not yet onboarded does not appear as a selectable option.
- Each payment point submission requires bank approval (US-PP-03) before becoming active.

### US-PP-03 — Bank approves a payment point

As a Bank, I want to review and approve or reject payment points submitted by merchants that reference my institution, so that only verified merchant-bank-point combinations are activated.

- When a merchant adds a payment point linked to Bank X, Bank X receives the pending request.
- Bank can approve or reject the request; the payment point's status updates accordingly.
- Only an Approved payment point can receive routed notifications.
- Confirmed: on approval or rejection, the merchant is notified of the bank's decision; a rejection notification includes a reason (BR-PP-12).
- Confirmed: the approval SLA is 1 working day; a Platform Operator tracks this on their dashboard (see Section 8.1).
- Confirmed: on rejection, the bank enters its reason in a free-text field on the approval screen — there is no fixed set of reason codes (BR-PP-18).

## 13.2 Payment Confirmation

### US-PP-04 — Method A: Code entry (offline-capable)

As a Merchant, I want to match a payment to an invoice by scanning a QR code on the customer's phone or manually entering the transaction code/reference the customer provides, without requiring a live connection, so that sales can proceed in low-connectivity conditions; the system verifies the match once back online.

- Merchant can capture the transaction code — either by scanning a QR code on the customer's phone or entering it manually — against an invoice while offline.
- Once connectivity is restored, the platform verifies the code against the actual bank notification.
- If verification fails (mismatched amount, duplicate code, no matching notification), the merchant is alerted.
- Confirmed: the platform's verification is limited to confirming the code/reference matches the value already relayed from the bank via the Payment Notification API — it is not an independent validation against the bank (BR-PP-13).

*Confirmed: if the same transaction code/reference can't be automatically matched — used against multiple invoices, or otherwise conflicting — reconciliation is manual, handled directly between the merchant and the bank; the platform does not resolve it automatically (BR-PP-16).*

### US-PP-05 — Method B: Notification tap (online)

As a Merchant, I want to tap an incoming payment notification on my cashier system to link it directly to the correct invoice while online, so that reconciliation happens immediately.

- Merchant receives a real-time notification for an incoming payment on their cashier system.
- Tapping the notification lets the merchant select/confirm the associated invoice.
- The match is recorded immediately with a Matched status.

## 13.3 Notification Delivery

### US-PP-06 — Merchant configures a Notification User

As a Merchant, I want to submit my ERP system's endpoint details (URL, Port) and credentials (Username, Password) as a Notification User, so that the platform can push payment notifications directly to my ERP.

- Available once the merchant's Interactive account is Active.
- Submission requires Platform Operator maker-checker approval before the Notification User becomes Approved (BR-PP-17).
- Only an Approved Notification User is used to receive pushed payment notifications.

### US-PP-07 — Platform Operator approves a Notification User

As a Platform Operator acting as Checker, I want to review and approve or reject a merchant's Notification User submission, so that payment notifications are only pushed to verified endpoints.

- The system blocks the checker step if the checker is the same user as the maker.
- On rejection, the merchant is notified and may resubmit.

### US-PP-08 — Platform pushes a payment notification to the merchant's ERP

As a Merchant, I want the platform to push each payment notification to my ERP system via my Approved Notification User endpoint, so that my ERP always has the latest transaction data without needing to poll.

- Uses the credentials and endpoint (URL, Port) configured in the merchant's Approved Notification User.
- Confirmed: delivery is push, not poll (see Section 14.3).

## 14. Referenced Foundational API

The source document already specifies one endpoint in detail; a second is now fully specified based on your feedback. Both are included here as-is because they will likely anchor the OpenAPI spec across the platform's services, not just Payment Points.

### 14.1 Bank / Wallet Login API

| Field     | Type   | Notes                             |
|-----------|--------|-----------------------------------|
| Request   |        |                                   |
| UserName  | string | Mandatory                         |
| Password  | string | Mandatory                         |
| Response  |        |                                   |
| IsSuccess | bool   | true on success, false on failure |

|            |        |                                                         |
|------------|--------|---------------------------------------------------------|
| Code       | string | e.g. 200 = Success, 401 = Invalid credentials           |
| Data.Token | string | JWT bearer token, used to authenticate subsequent calls |
| Message    | string | Human-readable result message                           |

**Sample success response:**

```
{ "IsSuccess": true, "Code": "200", "Data": { "Token": "<jwt>" }, "Message": "successful." }
```

**Sample failure response:**

```
{ "IsSuccess": false, "Code": "401", "Data": {}, "Message": "Invalid username or password." }
```

## 14.2 Payment Notification API (Bank → Platform)

Confirmed field-level schema for the notification a bank sends when a payment or refund event occurs. TransactionId is the idempotency key used to de-duplicate retried/duplicate notifications; PointNumber identifies which of the merchant's payment points it belongs to.

| Field               | Type     | Notes                                                                                                                                                    |
|---------------------|----------|----------------------------------------------------------------------------------------------------------------------------------------------------------|
| Request             |          |                                                                                                                                                          |
| TransactionId       | long     | Mandatory. The bank's unique payment ID — used as the idempotency key to de-duplicate retried/duplicate notifications (unique per transaction per bank). |
| TransactionStatus   | string   | Mandatory. Paid = "00002", Refunded = "00007".                                                                                                           |
| TransactionDate     | DateTime | Mandatory.                                                                                                                                               |
| Amount              | decimal  | Mandatory. Must be more than zero.                                                                                                                       |
| Currency            | string   | Mandatory. Confirmed: USD, SAR, and YER are supported.                                                                                                   |
| PointNumber         | string   | Mandatory. Merchant point number — identifies which of the merchant's payment points the notification belongs to.                                        |
| CashierId           | string   | Optional.                                                                                                                                                |
| CashierName         | string   | Optional.                                                                                                                                                |
| CustomerName        | string   | Mandatory. Masked based on the customer's privacy preferences.                                                                                           |
| CashierActivityName | string   | Mandatory. Branch name.                                                                                                                                  |
| Notes               | string   | Optional free-text note.                                                                                                                                 |
| Response            |          |                                                                                                                                                          |
| Name                | string   | Mandatory. Confirmed: a fixed label identifying the response (e.g. "Payment Response") — required, cannot be omitted.                                    |
| IsSuccess           | bool     | true on success, false on failure                                                                                                                        |
| Code                | string   | Response code, e.g. 200 = Success                                                                                                                        |
| Data.Reference      | string   | Mandatory. Platform-generated reference for the notification.                                                                                            |
| Message             | string   | Human-readable result message                                                                                                                            |

**Sample request:**

```
{ "TransactionId": 9876543210, "TransactionStatus": "00002", "TransactionDate": "2025-10-23T10:30:00Z", "Amount": 250.75, "Currency": "YER", "PointNumber": "10293", "CashierId": "10293#1",
```

```
"CashierName": "Alaa AlQersh", "CustomerName": "AbdulSalam Mashrah", "CashierActivityName": "Taiz Branch", "Notes": "Payment processed successfully at counter 5" }
```

#### Sample success response:

```
{ "Name": "Payment Response", "IsSuccess": true, "Code": 200, "Data": { "Reference": "892492685" }, "Message": "success" }
```

#### Sample failure response:

```
{ "IsSuccess": false, "Code": "HSN-001", "Data": { "Reference": "" }, "Message": "Invalid data input" }
```

### 14.3 Notification Delivery (Platform → Merchant ERP)

Confirmed: delivery is a push from the platform to the merchant's ERP system, not the merchant app polling the platform. The merchant configures a Notification User — endpoint URL, Port, and credentials (Username, Password) for their ERP — via the Merchant menu (US-PP-06); a Platform Operator approves it via maker-checker (US-PP-07). Once Approved, the platform pushes every Payment Notification it receives from a bank to that endpoint (US-PP-08). The exact push payload shape (expected to mirror the Section 14.2 schema plus the matched Payment Point/Invoice references) will be finalized during OpenAPI drafting.

## 15. Open Questions & Assumptions

*Only one question remains open, from the authentication and user-management sections above. Everything else in this document — across both the authentication foundation and the Payment Points service — has been confirmed with you directly, as reflected in the Business Rules and callouts throughout.*

#### Remaining

1. What should the Reports / Audit Log screen show — which metrics/events (e.g. approvals, logins, rejections), what filters, and is export required?

#### Resolved — Payment Points

*Confirmed: a Payment Point identifies a wallet number or a merchant point number (Section 12).*

*Confirmed: the full Payment Notification request/response schema is documented in Section 14.2, including field-level detail for TransactionId, TransactionStatus, Amount, Currency, PointNumber, CustomerName masking, and more.*

*Confirmed: merchants are onboarded via self-service Sign-Up or Platform-Operator-assisted onboarding (both maker-checker gated); Financial Institutions are onboarded exclusively by a Platform Operator (Maker) after contract signature, with Checker approval (Sections 3.3 and 7.3–7.4).*

*Confirmed: within a Financial Institution or Merchant account, approvals follow the platform-wide maker-checker model rather than free-form sub-roles; see Section 4 (Platform Operator roles) for the Maker/Checker/Reader/Admin structure.*

*Confirmed: when a payment can't be automatically matched — a Method A conflict, a mismatch, or an unmatched notification — reconciliation is manual, handled directly between the merchant and the bank. The platform does not provide an automated refund or escalation path (BR-PP-16).*

*Confirmed: duplicate/retried bank notifications are de-duplicated using TransactionId, which is unique per transaction per bank (BR-PP-14).*

*Confirmed: the platform supports multiple currencies — USD, SAR, and YER (BR-PP-15).*

*Confirmed: a merchant's multiple payment points are distinguished in the Payment Notification payload by the PointNumber field (Section 14.2).*

*Confirmed: notification delivery is a push from the platform to the merchant's ERP system, via a Notification User endpoint the merchant configures and a Platform Operator approves. See Sections 10.3, 13.3, and 14.3.*

*Confirmed: the Bank/Wallet Login API is reused as-is for Merchants (both use the same Interactive/Integration login flow), and tokens are scoped per institution/account. Token expiry/refresh is mutually agreed per institution rather than*

*fixed platform-wide — session tokens for Platform Operators are 30 minutes and for Merchants/Financial Institutions are 5 minutes; see Sections 4 and 6.*

*Confirmed: the approval SLA for a payment point request is 1 working day, tracked on the Platform Operator dashboard; on rejection, the bank enters a free-text reason rather than selecting from a fixed code list (BR-PP-18).*

*Confirmed: the sample Payment Notification request and response (Section 14.2) have been aligned with the field table ("PointNumber") and de-branded — the earlier "Haseb" naming was specific to a sample source and has been removed/replaced with generic terminology.*

*Confirmed: "Name" is a mandatory field in the Payment Notification response and cannot be dropped — it is now part of the documented schema (Section 14.2), holding a fixed label such as "Payment Response".*

## 16. Next Steps

- Sign-up/onboarding field lists in Section 6 are locked — includes the ERP System dropdown, the full contract field set, and the ERP System List screen.
- Menu & screen structure in Section 8 is locked, pending only the Reports/Audit Log scope (Section 15).
- Draft the OpenAPI 3.0 specification for Authentication & User Management: register, login (Interactive, with OTP), login (Integration, no OTP), verify-OTP, forgot-password, reset-password, invite-operator, create-FI (maker), create-merchant (self-service and operator-assisted), approve-request (checker), create-integration-user, rotate-integration-credential, view-integration-credential (OTP-gated), request-integration-change, manage-erp-system-list, manage-screen-permissions, update-own-profile.
- Draft the OpenAPI 3.0 specification for Payment Points: payment point CRUD + approval workflow, the Payment Notification API (Section 14.2), Notification User CRUD + approval workflow (Section 14.3), and the two MVP1 matching endpoints (Method A, Method B) — built on top of the authentication foundation above, including the Bank/Wallet Login API, which serves both Financial Institution and Merchant Integration users.